

Customer Support Q&A API

Node.js 20+ | Express 5 | OpenAI SDK | Helmet | Rate limiting | Stable JSON errors

DELIVERY	PROVIDER	SECURITY	QUALITY
Authenticated REST API	OpenAI Responses API	Strong bearer auth + limits	25 tests + coverage CI

Architecture

EDGE	APPLICATION	AI ADAPTER	OPERATIONS
Helmet, 32 KB JSON limit, auth-failure IP control, bearer authentication, paid-request limit.	Question schema, prompt boundaries, bundled policy context, response normalization.	Responses API, store: false, SDK timeout/retry, completed-response enforcement.	Live and ready health checks, safe logs, graceful shutdown, OpenAPI contract.

HTTP surface

METHOD	ROUTE	PURPOSE
GET	/health/live	Process liveness
GET	/health/ready	Required-secret readiness
POST	/support/ask	Authenticated support answer

Public error contract

400	invalid_request / invalid_json	401	unauthorized
413	payload_too_large	429	rate_limited
502	provider_error	503/504	readiness, provider limit, or timeout

Security and resilience

- Validated independent inbound secret	- store: false provider requests
- Timing-safe authentication	- Completed output required
- Bounded request size and question length	- Redacted public errors
- Configurable proxy trust	- Per-process rate limiting

Verification

25 tests exercise application logic and the local HTTP surface without paid provider calls. CI enforces coverage and validates OpenAPI plus 32 versioned evaluation cases on Node.js 20, 22, and 24.

Run locally

npm ci	npm run check	npm start
--------	---------------	-----------

Production rollout adds managed secrets, TLS, centralized observability, distributed rate limiting, approved policy content, and representative quality evaluations.